

CÂMARA MUNICIPAL DO RECIFE

Participação Popular · Resolução nº 2.690/2018

Banco de Ideias Legislativas

Especificação técnica, arquitetura, segurança da informação e plano de implantação de um sistema web para registro, triagem, análise parlamentar e consulta pública de ideias legislativas apresentadas pelo cidadão.

Documento	Especificação Técnica — v1.0
Data	27 de agosto de 2026
Classificação	Interno — proposta para avaliação técnica
Destinatário	Coordenação / Diretoria de Tecnologia da Informação
Elaborado por	_____

Natureza deste documento. Trata-se de uma proposta técnica submetida à avaliação. Nenhuma decisão aqui descrita foi implantada, e nenhum componente descrito está em operação. Números de dimensionamento e de esforço são estimativas, sinalizadas como tal no texto.

Sumário

1. Sumário executivo

O problema, a solução proposta e o que muda

2. Situação atual

Diagnóstico do formulário em produção e suas lacunas

3. Escopo funcional

Os quatro fluxos, telas novas e critérios de aceite

4. Arquitetura da solução

Camadas, stack e justificativa de cada escolha

5. Modelo de dados

Entidades, relacionamentos, índices e decisões de modelagem

6. Regras de tramitação

Máquina de estados e imutabilidade do histórico

7. Interface de programação (API)

Endpoints, contratos e dados abertos

8. Segurança da informação

AuthN/AuthZ, criptografia, OWASP Top 10, auditoria

9. Adequação à LGPD

Bases legais, inventário de dados, retenção e direitos

10. Acessibilidade e conformidade legal

eMAG, WCAG 2.1 AA, LAI

11. Infraestrutura, implantação e operação

Ambientes, CI/CD, backup, observabilidade

12. Integração com o portal institucional

Subdomínio, iframe ou proxy reverso

13. Plano de implantação

Fases, entregáveis, esforço e dependências

14. Riscos e mitigações

Matriz de riscos técnicos, legais e de adoção

15. Roadmap posterior (v2)

O que ficou fora do escopo inicial e por quê

16. Glossário

Termos legislativos e termos de tecnologia

1. Sumário executivo

A Câmara Municipal do Recife instituiu, pela **Resolução nº 2.690/2018** (originada do Projeto de Resolução nº 23/2018), o *Banco de Ideias Legislativas* — canal pelo qual o cidadão apresenta sugestões que podem ser adotadas por vereadores e transformadas em proposições. A finalidade é legítima e o instrumento existe. O que não existe é **o sistema que sustenta o ciclo completo**.

Hoje, o canal disponível no portal é um **formulário de coleta**: recebe os dados e os encaminha. Não gera número de protocolo, não registra a triagem, não oferece um painel aos gabinetes, não publica o acervo e — o ponto mais crítico — **não devolve nada ao cidadão**. Quem envia uma ideia não descobre se ela foi lida, aceita, encaminhada ou descartada, nem por quê.

Este documento especifica a substituição desse formulário por um **sistema de tramitação participativa**, hospedado em subdomínio próprio, com identidade visual alinhada à do portal. Ele implementa quatro fluxos encadeados e auditáveis:

Etapa	Ator	O que o sistema passa a fazer
1. Cadastro	Cidadão ou entidade	Registra a ideia com identificação obrigatória (CPF/CNPJ validado), emite número de protocolo e comprovante, e verifica se já existe ideia semelhante
2. Triagem	Servidor da Secretaria	Analisa conteúdo e identificação; torna a ideia Disponível ou a Arquiva com justificativa obrigatória , com prazo monitorado
3. Análise parlamentar	Gabinete ou comissão	Consulta o acervo disponível, declara Em Análise e, se for o caso, Adota a ideia — tudo registrado com autoria e data
4. Consulta pública	Qualquer pessoa	Consulta todo o acervo triado, com página própria por ideia, linha do tempo de tramitação e possibilidade de apoiar

1.1 O que muda, na prática

- **Rastreabilidade.** Toda mudança de situação grava um registro permanente com autor, data e justificativa. Não existe alteração de status sem rastro.
- **Devolutiva ao cidadão.** Com protocolo e CPF, o autor acompanha o andamento e, em caso de arquivamento, **lê o motivo**.
- **Ganho operacional na Secretaria.** Fila priorizada por prazo, filtros, ações em lote e exportação substituem o controle manual por planilha e e-mail.
- **Sinal de prioridade para os gabinetes.** Ideias semelhantes deixam de se multiplicar: o cidadão *apoia* a existente, e o volume de apoios ordena o painel.
- **Transparência ativa.** Painel de indicadores e endpoint de dados abertos em JSON/CSV, sem dados pessoais, atendendo à Lei de Acesso à Informação.

PONTO CENTRAL PARA A AVALIAÇÃO TÉCNICA

O desafio deste sistema **não é escala** — o volume esperado é de dezenas a poucas centenas de registros por mês, carga trivial para qualquer stack moderna. O desafio é **conformidade**: tratar CPF de cidadãos sob a LGPD, atender à acessibilidade digital exigida por lei, e produzir uma trilha de auditoria que resista a questionamento. As seções 8, 9 e 10 são, por isso, as mais densas deste documento.

2. Situação atual

2.1 O que existe em produção

O canal atual, publicado em `/participacao-popular/banco-de-ideias-legislativas`, é uma página do portal institucional (Plone/Zope, Python) contendo um formulário com os campos: nome, e-mail, área temática, título da ideia, descrição e detalhamento complementar. A submissão encerra a interação — não há retorno estruturado ao remetente nem estado persistido que descreva o que ocorre em seguida.

2.2 Lacunas identificadas

Lacuna	Consequência prática
Sem número de protocolo	Não há identificador estável para o cidadão citar, para a Secretaria referenciar nem para o gabinete rastrear. Toda comunicação posterior depende de busca por nome.
Sem registro de triagem	A análise, se ocorre, acontece fora do sistema (e-mail, planilha). Não é possível responder oficialmente quem analisou, quando, e com que fundamento.
Sem painel para gabinetes	A distribuição das ideias aos vereadores depende de encaminhamento manual. Não há registro de qual gabinete analisou ou adotou o quê.
Sem consulta pública	O acervo é invisível. O cidadão não sabe o que já foi proposto — o que produz duplicidade e impede controle social sobre o programa.
Sem devolutiva	É a falha mais sensível reputacionalmente: o cidadão participa e recebe silêncio, o que desestimula a participação seguinte.
Identificação frágil	A Resolução exige identificação do autor. Coletar apenas nome e e-mail, sem documento validado, não sustenta a exigência nem impede envios em massa.
Sem indicadores	Não há como responder quantas ideias chegaram, sobre quais temas, de quais regiões, nem quantas viraram proposição — informação necessária para prestação de contas.

OBSERVAÇÃO DE ESCOPO

O diagnóstico acima foi construído a partir da **observação externa da página pública**. É possível que existam controles internos (planilhas, protocolo SEI, rotinas da Secretaria) não visíveis externamente. Recomenda-se validar esta seção com a Secretaria responsável antes da decisão final — se já houver protocolo institucional em uso, o sistema deve *referenciá-lo* em vez de criar numeração concorrente.

3. Escopo funcional

3.1 Perfis de acesso

Perfil	Autenticação	Permissões
Cidadão	Não autenticado	Cadastrar ideia, consultar acervo público, apoiar ideia, acompanhar a própria ideia via protocolo + CPF
Servidor (Triagem)	Login interno	Ver fila de pendentes, revelar CPF sob registro, editar redação, aprovar (Disponível) ou arquivar com justificativa, exportar relatórios
Gabinete	Login interno	Consultar acervo disponível, declarar Em Análise, Adotar, devolver ao acervo, exportar a carteira do gabinete
Administrador	Login interno	Gerir usuários e temas, consultar trilha de auditoria, arquivar em qualquer situação com justificativa, atender requisições de titulares (LGPD)

3.2 Etapa 1 — Cadastro da ideia pelo cidadão

O formulário único é substituído por um assistente de quatro passos. A motivação é concreta: formulário longo em página única tem abandono alto em telefone celular — origem provável da maioria dos acessos — e não previne duplicidade.

Passo	Conteúdo e regras
1. Sua ideia já existe?	Busca textual no acervo já publicado. Havendo semelhante, o sistema oferece “Apoiar esta ideia” como alternativa a criar outro registro. É opcional — o cidadão pode seguir e cadastrar assim mesmo.
2. A ideia	Tema (lista controlada), título (até 150 caracteres), descrição (até 5.000, com contador visível), bairro e RPA. Rascunho preservado localmente entre passos.
3. Identificação	Tipo de autor (pessoa física / jurídica), CPF ou CNPJ com validação de dígito verificador — não apenas máscara —, nome ou razão social, e-mail, telefone opcional. Dois consentimentos separados : ciência do tratamento de dados e autorização (opcional) para divulgação do nome.
4. Confirmação	Número de protocolo em destaque, token de acompanhamento, comprovante para download e informação do prazo de triagem.

CRITÉRIOS DE ACEITE

- CPF ou CNPJ inválido no dígito verificador **bloqueia** o envio, com mensagem de erro associada ao campo e anunciada a leitores de tela.
- O protocolo é único, sequencial por ano e no formato [BIL-2026-000123](#) .
- Reenvio do mesmo formulário (duplo clique, retorno do navegador) **não** cria segundo registro — proteção por chave de idempotência.
- O consentimento de divulgação do nome, quando não marcado, resulta em exibição pública como “Cidadão(ã) do Recife”.

3.3 Etapa 2 — Triagem pelo servidor

Mantém a estrutura de tabela dos protótipos aprovados, acrescentando os controles que tornam a decisão auditável:

- **Fila ordenada por prazo**, com indicador de SLA (sugestão: 15 dias úteis, parametrizável) e destaque para itens vencidos.
- **Arquivamento exige motivo**, escolhido em lista controlada — fora da competência do município, conteúdo ofensivo, duplicidade, identificação inválida, texto incompreensível — **somado a** justificativa em texto livre.
- **Edição de redação** para correção ortográfica e de clareza, **preservando o texto original** no histórico.
- **CPF mascarado por padrão** (111.***.***-44); a revelação é uma ação explícita que grava quem revelou, quando e sobre qual registro.
- Busca, filtros por tema e período, ações em lote e exportação em CSV e PDF.

3.4 Etapa 3 — Painel do gabinete

- Ordenação por **número de apoios**, data ou tema — o volume de apoio popular passa a orientar a priorização.
- **Múltiplos gabinetes podem manifestar interesse na mesma ideia**. Decisão deliberada: reserva exclusiva por ordem de clique geraria disputa e travaria o acervo.
- Ao adotar, registra-se o gabinete responsável, a data e uma observação.
- Visão “minhas ideias em análise” e exportação da carteira do gabinete.

3.5 Etapa 4 — Consulta pública

- Cada ideia recebe **endereço próprio** (/consulta/BIL-2026-000123) com descrição completa, linha do tempo da tramitação e botão de apoio.
- Filtros por tema, situação, período e RPA; ordenação por mais recentes ou mais apoiadas.
- Renderização no servidor, tornando as páginas indexáveis por buscadores e legíveis por leitores de tela sem depender de JavaScript.
- O motivo do arquivamento **não** é exibido publicamente — apenas ao autor, na área de acompanhamento (ver seção 9).

3.6 Telas adicionais

Tela	Função e justificativa
Acompanhar minha ideia	Autenticação leve por protocolo + CPF (ou token do comprovante). Exibe situação atual, linha do tempo e, se arquivada, o motivo. Responde diretamente à lacuna mais grave do canal atual.
Indicadores públicos	Ideias por tema e por RPA, tempo médio de triagem, taxa de aprovação e taxa de adoção. Insumo pronto para prestação de contas e para a Comunicação.
Dados abertos	Endpoint em JSON e CSV, sem qualquer dado pessoal, permitindo reuso por imprensa, academia e organizações da sociedade civil.

4. Arquitetura da solução

4.1 Visão em camadas

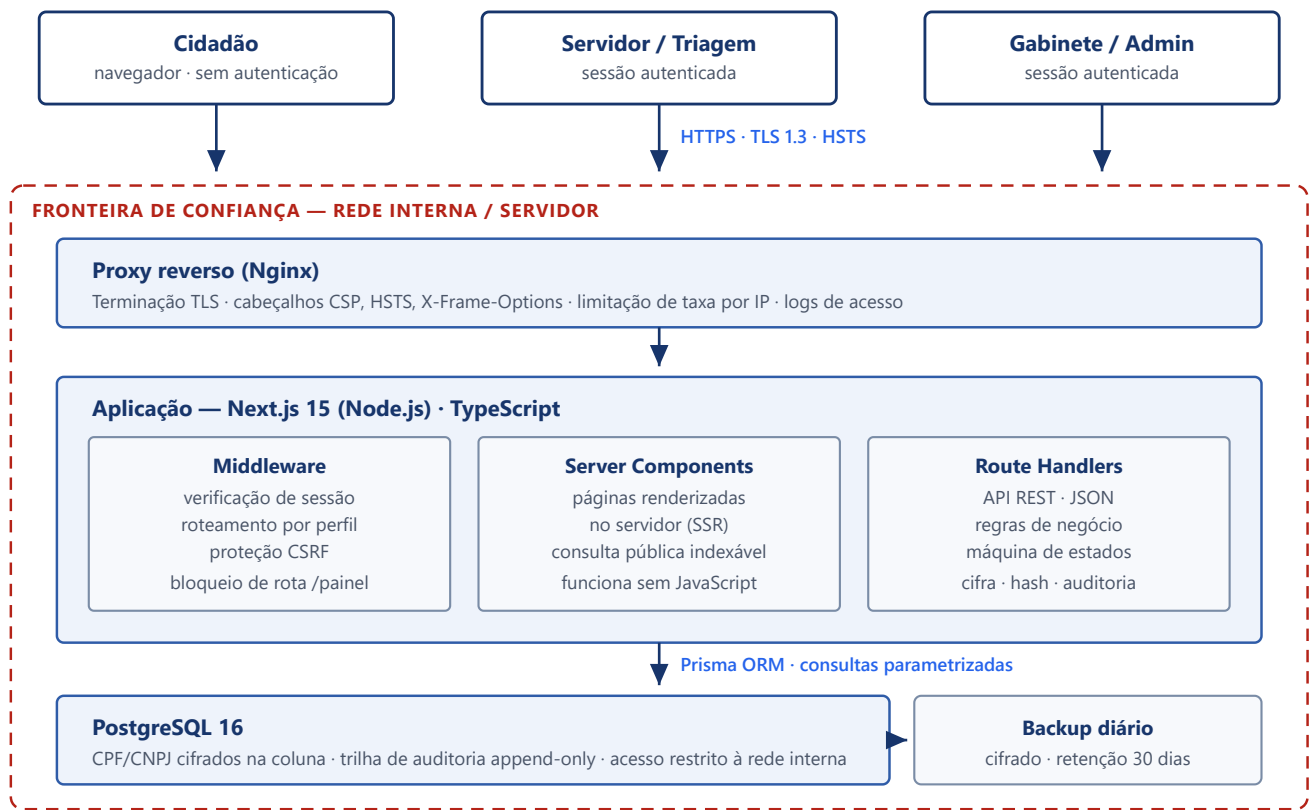


Figura 1. O navegador nunca alcança o banco. Toda regra de negócio e toda decisão de autorização executam no servidor; o cliente é apenas apresentação.

4.2 Stack proposta e justificativa

Componente	Escolha	Por quê
Framework web	Next.js 15 (App Router)	Renderização no servidor por padrão — requisito para que a consulta pública seja indexável e acessível sem JavaScript. Um só projeto entrega páginas e API, reduzindo superfície operacional.
Linguagem	TypeScript	Tipagem estática cobre a fronteira mais arriscada do sistema: os estados de tramitação e os contratos de API. Erro de transição vira erro de compilação.
Banco de dados	PostgreSQL 16	Transacional, maduro, sem custo de licença, com tipos <code>enum</code> nativos e restrições de unicidade que sustentam as regras deste domínio.
Acesso a dados	Prisma ORM	Consultas parametrizadas por construção (mitiga injeção de SQL) e migrações versionadas em arquivo, auditáveis em revisão de código.
Estilo	Tailwind CSS	Design tokens centralizados — a paleta institucional é definida uma vez e aplicada de forma consistente.
Autenticação	Auth.js (credenciais) + argon2id	Sessão em cookie assinado, sem token no armazenamento do navegador. Preparado para receber provedor OIDC/LDAP na v2 sem reescrita.
Testes	Vitest + Playwright	Unitários nas regras críticas (validação de documento, máquina de estados) e ponta a ponta no fluxo completo das quatro etapas.
Empacotamento	Docker + Docker Compose	Ambiente reproduzível; elimina divergência entre a máquina do desenvolvedor e o servidor da Câmara.

CONTRAPARTIDA A CONSIDERAR — LEITURA HONESTA DO TRADE-OFF

O portal institucional roda **Plone (Python/Zope)**. Adotar Next.js **introduz Node.js no parque tecnológico**, o que significa uma segunda cadeia de atualização de segurança, um segundo conjunto de competências na equipe e um segundo processo de *build*. Isso é um custo real e deve pesar na decisão.

A alternativa — construir dentro do Plone — evitaria esse custo, mas herdaria o ciclo de publicação do CMS institucional, acoplaria a evolução do sistema à do portal e obrigaria a implementar em Zope um modelo de tramitação, papéis e auditoria que os frameworks modernos já oferecem. **Se a Diretoria de TI preferir consolidar no ecossistema Python, a recomendação alternativa é Django:** mantém a linguagem já dominada pela equipe, traz painel administrativo pronto (útil para a Triagem) e um sistema de permissões maduro. Toda a modelagem, as regras e os controles descritos nas seções 5 a 11 deste documento são **independentes de framework** e se aplicam integralmente a essa alternativa.

5. Modelo de dados

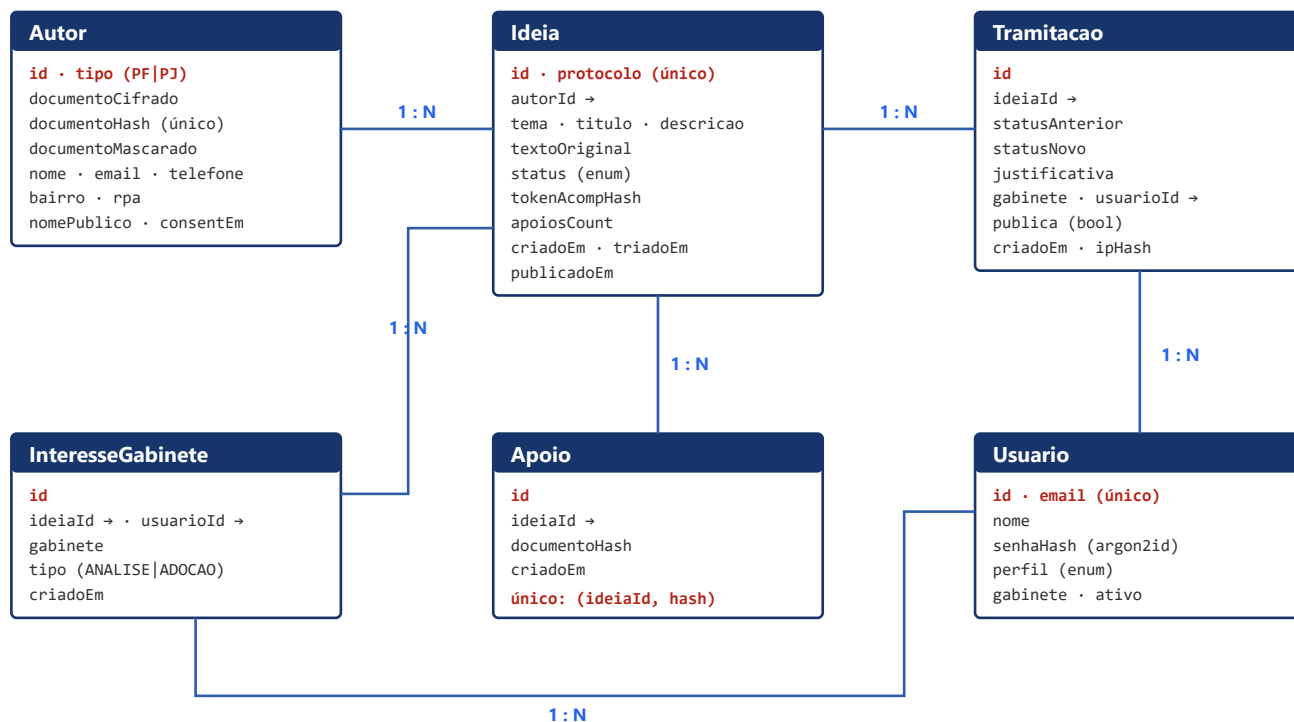


Figura 2. Seis entidades. Os dados pessoais concentram-se em **Autor**, o que simplifica atender a requisições de titulares e definir a política de retenção.

5.1 Esquema (Prisma)

```
// Dados pessoais isolados em uma única entidade – facilita retenção e exclusão (LGPD).
model Autor {
  id          String    @id @default(cuid())
  tipo        TipoAutor // FISICA | JURIDICA
  documentoCifrado String // AES-256-GCM; chave fora do código
  documentoHash String   @unique // SHA-256 c/ pepper: dedupe sem decifrar
  documentoMascarado String // "111.***.***-44" – o que a tela mostra
  nome        String
  email       String
  telefone    String?
  bairro      String?
  rpa         Int?      // 1..6 – Regiões Político-Administrativas
  nomePublico Boolean @default(false) // consentimento explícito e revogável
  consentimentoEm DateTime
  ideias      Ideia[]
}

model Ideia {
  id          String    @id @default(cuid())
  protocolo    String    @unique // BIL-2026-000123
  tokenAcompHash String // hash do token do comprovante
  autorId      String
  autor        Autor     @relation(fields: [autorId], references: [id])
  tema         String
  titulo       String    @db.VarChar(150)
  descricao    String    @db.VarChar(5000)
  textoOriginal String?  @db.VarChar(5000) // preservado se a Triagem editar
  status       StatusIdeia @default(RECEBIDA)
  apoiosCount  Int        @default(0)
  criadoEm     DateTime   @default(now())
  triadoEm     DateTime?
  publicadoEm  DateTime?
  tramitacoes Tramitacao[]
  apoios       Apoio[]
  interesses   InteresseGabinete[]

  @@index([status, publicadoEm]) // consulta pública
  @@index([status, criadoEm])   // fila de triagem por prazo
}

// Linha do tempo pública E trilha de auditoria são a MESMA tabela – ver seção 6.3.
model Tramitacao {
  id          String    @id @default(cuid())
  ideiaId     String
  ideia       Ideia     @relation(fields: [ideiaId], references: [id])
  statusAnterior StatusIdeia?
  statusNovo  StatusIdeia
  justificativa String? // OBRIGATÓRIA no arquivamento
  gabinete    String?
  usuarioId   String?
  publica     Boolean    @default(true) // false = só auditoria interna
  ipHash      String?
  criadoEm    DateTime   @default(now())

  @@index([ideiaId, criadoEm])
}

model Apoio {
  id          String    @id @default(cuid())
```

```

ideiaId      String
ideia        Ideia    @relation(fields: [ideiaId], references: [id])
documentoHash String    // nunca o CPF em claro
criadoEm     DateTime @default(now())

@@unique([ideiaId, documentoHash]) // um apoio por documento por ideia
}

model Usuario {
  id      String @id @default(cuid())
  nome    String
  email   String @unique
  senhaHash String    // argon2id
  perfil  Perfil       // TRIAGEM | GABINETE | ADMIN
  gabinete String?
  ativo   Boolean @default(true)
}

enum StatusIdeia { RECEBIDA EM_TRIAGEM DISPONIVEL EM_ANALISE ADOTADA ARQUIVADA }
enum Perfil      { TRIAGEM GABINETE ADMIN }
enum TipoAutor   { FISICA JURIDICA }

```

5.2 Decisões de modelagem que merecem atenção

Decisão	Fundamento
Três colunas para um documento (cifrado, hash, mascarado)	Cada uma serve a um uso distinto: o cifrado só é decifrado sob ação explícita e registrada; o hash permite verificar duplicidade e apoio repetido sem decifrar nada; a máscara atende à tela da Triagem no dia a dia. Resultado: o CPF em claro quase nunca é manipulado.
apoiosCount desnormalizado	Evita COUNT em toda listagem pública. Atualizado na mesma transação do INSERT em Apoio , o que preserva a consistência.
textoOriginal preservado	Se a Triagem corrige a redação, a versão enviada pelo cidadão permanece registrada. Protege a Câmara de alegação de alteração indevida de conteúdo.
ipHash , não IP	Permite detectar envio automatizado em massa sem manter endereço IP em claro, reduzindo o volume de dado pessoal retido.
Sem exclusão física de ideias	Arquivar é mudança de estado, não remoção. Registro de participação popular não deve desaparecer do acervo.

6. Regras de tramitação

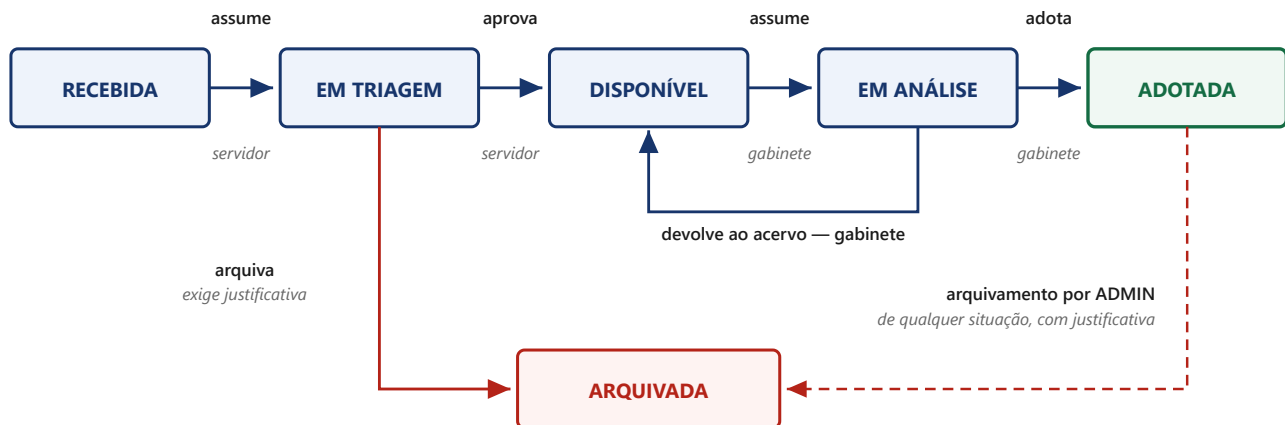


Figura 3. Nenhuma outra transição é aceita. Tentativa de transição fora deste grafo retorna 422 e é registrada como evento de auditoria.

6.1 Situações e seus significados

Situação	Visível ao público?	Significado
RECEBIDA	Não	Registrada, aguardando início da triagem
EM TRIAGEM	Não	Servidor assumiu a análise (evita dois servidores no mesmo item)
DISPONÍVEL	Sim	Aprovada, publicada no acervo e ofertada aos gabinetes
EM ANÁLISE	Sim	Um ou mais gabinetes manifestaram interesse formal
ADOTADA	Sim	Gabinete assumiu a ideia para conversão em proposição
ARQUIVADA	Parcial	Não prossegue. O motivo é exibido ao autor , não ao público

6.2 Validação no servidor

A máquina de estados é implementada em `lib/maquina-status.ts` e verificada em **toda** rota de mutação. A interface esconde botões inválidos por conveniência, nunca como mecanismo de segurança:

```
const TRANSICOES: Record<StatusIdea, { para: StatusIdea[]; perfis: Perfil[] }> = {
  RECEBIDA: { para: ['EM_TRIAGEM'], perfis: ['TRIAGEM', 'ADMIN'] },
  EM_TRIAGEM: { para: ['DISPONIVEL', 'ARQUIVADA'], perfis: ['TRIAGEM', 'ADMIN'] },
  DISPONIVEL: { para: ['EM_ANALISE', 'ARQUIVADA'], perfis: ['GABINETE', 'ADMIN'] },
  EM_ANALISE: { para: ['ADOTADA', 'DISPONIVEL', 'ARQUIVADA'], perfis: ['GABINETE', 'ADMIN'] },
  ADOTADA: { para: ['ARQUIVADA'], perfis: ['ADMIN'] },
  ARQUIVADA: { para: [], perfis: [] },
};

// Regra dura: arquivar sem justificativa é rejeitado antes de tocar o banco.
if (destino === 'ARQUIVADA' && !justificativa?.trim()) throw new ErroValidacao(422);
```

6.3 Por que a linha do tempo pública e a auditoria são a mesma tabela

DECISÃO DE PROJETO

Sistemas de tramitação costumam manter um histórico exibido ao público e um log de auditoria separado. Isso permite que os dois divirjam — e, quando divergem, nenhum dos dois tem valor probatório.

Aqui, **a única forma de alterar o status de uma ideia é gravando uma linha em `Tramitacao`**, na mesma transação. A flag `publica` controla apenas o que aparece na tela, jamais se o registro existe. Consequência: **não existe mudança de situação sem rastro**, e o que o cidadão vê é literalmente derivado do mesmo registro que a auditoria interna consulta.

Reforço no banco: revogação de `UPDATE` e `DELETE` sobre `Tramitacao` para o usuário da aplicação, que recebe apenas `INSERT` e `SELECT`. A tabela torna-se, na prática, *append-only*.

7. Interface de programação (API)

7.1 Endpoints

Método	Rota	Perfil	Função
POST	/api/ideias	Público	Cadastra ideia; retorna protocolo e token. Limitado por taxa e idempotente
GET	/api/ideias	Público	Lista o acervo triado, com filtros e paginação. Nunca retorna dado pessoal
GET	/api/ideias/{protocolo}	Público	Detalhe da ideia com a linha do tempo pública
POST	/api/ideias/{id}/apoiar	Público	Registra apoio; recusa repetição do mesmo documento na mesma ideia
POST	/api/acompanhar	Público	Consulta por protocolo + CPF; devolve situação e motivo de arquivamento
POST	/api/ideias/{id}/tramitar	Interno	Executa transição de estado. Valida grafo, perfil e justificativa
POST	/api/ideias/{id}/revelar-documento	Triagem/Admin	Decifra e retorna o documento; grava evento de auditoria obrigatoriamente
GET	/api/dados-abertos	Público	Acervo completo em JSON ou CSV, sem qualquer dado pessoal (LAI)
GET	/api/indicadores	Público	Séries agregadas para o painel de indicadores

7.2 Contrato de exemplo

```
// POST /api/ideias/{id}/tramitar
// Cabeçalhos: Cookie de sessão + X-CSRF-Token
{ "destino": "ARQUIVADA",
  "motivo": "FORA_DA_COMPETENCIA_MUNICIPAL",
  "justificativa": "Matéria de competência estadual (Art. 30, CF)." }

// 200 OK
{ "protocolo": "BIL-2026-000123", "status": "ARQUIVADA",
  "tramitacaoId": "ckv...", "registradoEm": "2026-08-27T14:12:03Z" }

// Erros previstos
// 401 sem sessão • 403 perfil sem permissão • 409 alterada por outro usuário
// 422 transição fora do grafo, ou arquivamento sem justificativa
// 429 limite de requisições excedido
```

CONCORRÊNCIA

Dois servidores podem abrir o mesmo item ao mesmo tempo. A transição envia a versão conhecida do registro; se a situação no banco já mudou, a resposta é **409** com a situação atual, e a interface pede recarregamento — em vez de sobrescrever silenciosamente a decisão do colega.

8. Segurança da informação

8.1 Autenticação

Controle	Especificação
Derivação de senha	argon2id , memória 19 MiB, 2 iterações, paralelismo 1 (parâmetros mínimos recomendados pela OWASP). Sal único por usuário, gerado por CSPRNG.
Sessão	Cookie assinado com <code>HttpOnly</code> , <code>Secure</code> , <code>SameSite=Lax</code> , <code>Path=/</code> . Nenhum token em <code>localStorage</code> — o que neutraliza roubo de sessão via XSS.
Expiração	Sessão inativa expira em 30 minutos; absoluta em 8 horas. Renovação do identificador de sessão no login (previne <i>session fixation</i>).
Política de senha	Mínimo 12 caracteres, verificação contra lista de senhas vazadas (k-anonymity, sem enviar a senha). Sem expiração compulsória — alinhado ao NIST SP 800-63B.
Força bruta	Atraso progressivo e bloqueio temporário por conta e por IP. Mensagem de erro genérica, que não revela se o e-mail existe.
Acesso do cidadão	Sem conta. O acompanhamento usa protocolo + CPF — dois fatores que só o autor detém — com limitação de tentativas para impedir varredura de protocolos.

8.2 Autorização

Controle de acesso baseado em papéis, verificado **no servidor, em cada rota**. Três camadas independentes, de modo que a falha de uma não abre o sistema:

1. **Middleware** — bloqueia qualquer rota sob `/painel` sem sessão válida, antes de a página existir.
2. **Route Handler** — revalida o perfil contra a operação pedida. Uma requisição forjada direto à API encontra a mesma checagem que a interface.
3. **Máquina de estados** — cada transição declara quais perfis podem executá-la (seção 6.2). Gabinete não arquiva; Triagem não adota.

RISCO NÚMERO 1 NESTA CLASSE DE SISTEMA

Broken Access Control é a categoria mais explorada segundo a OWASP, e a forma mais comum é a rota de API que confia na interface. Por isso a regra adotada aqui é categórica: **toda rota de mutação verifica sessão e perfil por conta própria**, sem depender de qualquer verificação feita antes. O teste de aceite correspondente está na seção 13.

8.3 Proteção do dado sensível — o caminho do CPF

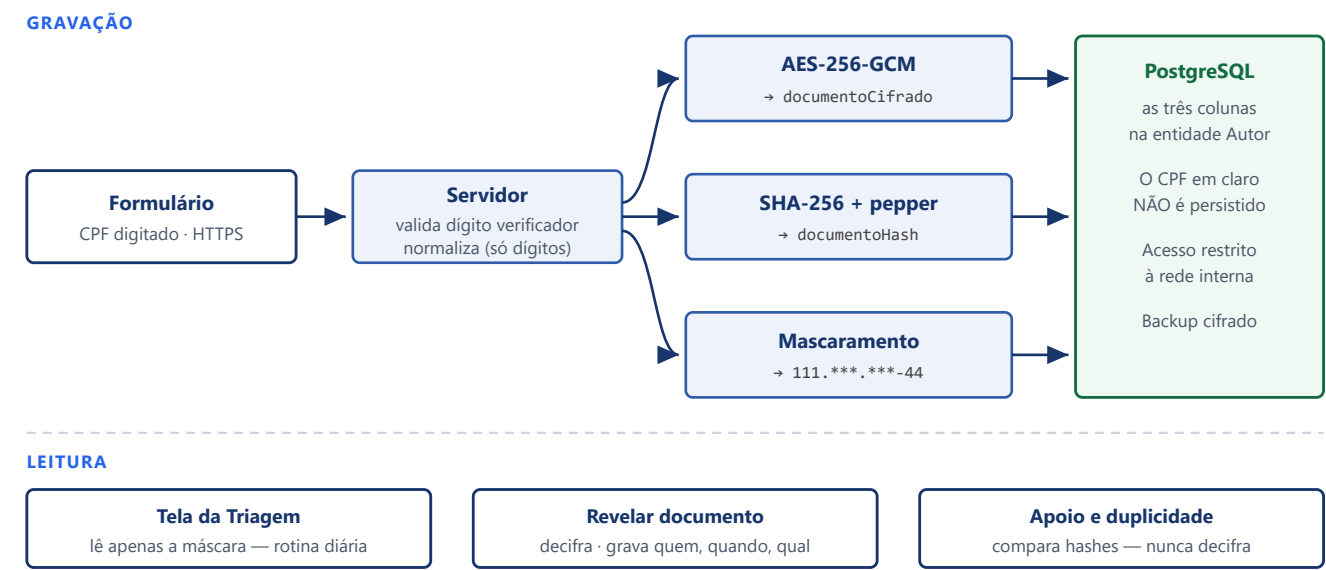


Figura 4. O CPF em claro existe apenas em memória, durante a requisição de gravação e durante uma revelação explícita e registrada. Nenhuma outra operação do sistema precisa dele.

Controle	Especificação
Cifra em repouso	AES-256-GCM (cifra autenticada — detecta adulteração do texto cifrado), nonce único por registro, aplicada na aplicação antes da persistência.
Chave de cifra	Fora do código e fora do repositório: variável de ambiente injetada na implantação, idealmente de cofre. Procedimento de rotação documentado, com recifragem em lote.
Hash de busca	SHA-256 com <i>pepper</i> em segredo de aplicação. Sem o pepper, um dump do banco não permite testar CPFs candidatos — o espaço de CPFs é pequeno o bastante para ser enumerado sem essa proteção.
Cifra em trânsito	TLS 1.3 obrigatório, HSTS com <code>max-age</code> de 1 ano, redirecionamento permanente de HTTP para HTTPS.
Minimização	Respostas públicas e endpoint de dados abertos não contêm documento, e-mail, telefone nem IP. Verificado por teste automatizado (seção 13).

8.4 OWASP Top 10 (2021) — tratamento item a item

Categoria	Controle adotado
A01 Broken Access Control	Autorização em três camadas (8.2); máquina de estados restringe transição por perfil; identificadores <code>cuid()</code> não sequenciais; teste automatizado que chama rotas internas sem sessão e com perfil incorreto
A02 Cryptographic Failures	AES-256-GCM em repouso, TLS 1.3 em trânsito, argon2id para senhas, pepper no hash de busca, segredos fora do repositório
A03 Injection	Consultas parametrizadas pelo Prisma; validação de esquema com Zod na borda; saída escapada por padrão pelo React; ausência de SQL concatenado
A04 Insecure Design	Máquina de estados explícita; limite de taxa desenhado desde o início; justificativa obrigatória no arquivamento como regra de domínio, não de tela
A05 Security Misconfiguration	CSP restritiva sem <code>unsafe-inline</code> ; <code>X-Frame-Options: DENY</code> ; <code>X-Content-Type-Options: nosniff</code> ; <code>Referrer-Policy</code> ; páginas de erro sem <code>stack trace</code> ; contas padrão inexistentes
A06 Vulnerable Components	<code>npm audit</code> e Dependabot no pipeline; build falha em vulnerabilidade alta ou crítica; versões fixadas por <code>lockfile</code>
A07 Authentication Failures	Bloqueio progressivo, mensagens genéricas, rotação de sessão no login, expiração por inatividade (8.1)
A08 Data Integrity Failures	<code>Tramitacao</code> append-only com <code>UPDATE</code> / <code>DELETE</code> revogados no banco; imagens de container com origem fixada; migrações versionadas
A09 Logging & Monitoring Failures	Registro estruturado de login, falha de login, transição de estado, revelação de documento e erro 5xx; retenção de 12 meses; alerta em picos anômalos
A10 SSRF	A aplicação não realiza requisições a URLs fornecidas pelo usuário. Superfície inexistente por projeto

8.5 Prevenção a abuso e envio automatizado

- Limite por IP: 5 cadastros por hora
- Limite por documento: 3 ideias por dia
- Campo-armadilha invisível (*honeypot*)
- Tempo mínimo de preenchimento do formulário
- Validação de dígito verificador de CPF e CNPJ
- Chave de idempotência contra reenvio duplicado
- Apoio único por documento por ideia (restrição no banco)
- Limite de tentativas em “Acompanhar minha ideia”

SOBRE CAPTCHA

Um CAPTCHA de terceiros criaria dependência de serviço externo, transferiria dados de navegação de cidadãos a um fornecedor privado e prejudicaria a acessibilidade. A recomendação é **começar sem CAPTCHA**, com os controles acima, e reavaliar com base em métricas reais de abuso. Se necessário, priorizar solução autoexecutável e acessível (por exemplo, desafio de prova de trabalho) em vez de reconhecimento de imagem.

8.6 Trilha de auditoria

São registrados, de forma permanente: autenticação e falha de autenticação; toda transição de estado com autor, data, justificativa e situação anterior; **toda revelação de CPF**, com o servidor responsável e o registro

acessado; criação, alteração e desativação de usuários; e exportações de dados. A consulta à trilha é restrita ao perfil Administrador e é ela própria registrada.

8.7 Gestão de segredos e ciclo de desenvolvimento

- Nenhum segredo no repositório; `.env.example` documenta as variáveis sem valores. Varredura de segredos no pipeline.
- Segredos distintos por ambiente. Credencial de produção jamais em máquina de desenvolvimento.
- Banco de desenvolvimento populado com **dados fictícios**; cópia de produção nunca é usada para desenvolver ou testar.
- Revisão de código obrigatória antes da integração; nenhum envio direto ao ramo principal.
- Recomenda-se **teste de intrusão** antes da entrada em produção, pela própria equipe de segurança da Câmara ou por terceiro contratado.

9. Adequação à LGPD (Lei nº 13.709/2018)

9.1 Bases legais — a distinção que sustenta o desenho

PONTO JURÍDICO CENTRAL

Há duas operações distintas com bases legais **diferentes**, e tratá-las como uma só seria o erro mais provável neste projeto:

(a) Coletar CPF/CNPJ e identificar o autor. Decorre de **obrigação normativa** — a Resolução nº 2.690/2018 exige identificação — e da execução de política pública de participação popular. Enquadra-se nos **arts. 7º, II e III, e 23 da LGPD**. *Não é* baseada em consentimento; por isso o cidadão não pode “desmarcar” a identificação e ainda assim participar, e a Câmara não fica refém de revogação para manter o registro do ato.

(b) Divulgar publicamente o nome do autor. Não é exigida por norma alguma e não é necessária para a finalidade. Portanto é tratamento por **consentimento (art. 7º, I)**: opcional, específico, destacado dos demais textos e **revogável a qualquer tempo**. Sem consentimento, a consulta pública exibe “Cidadão(ã) do Recife”.

9.2 Inventário de dados pessoais

Dado	Finalidade	Base legal	Quem acessa	Publicidade
CPF / CNPJ	Identificação exigida pela Resolução; unicidade de apoio	Arts. 7º, II/III e 23	Triagem e Admin, sob registro	Nunca público
Nome / razão social	Identificação do autor	Arts. 7º, II/III e 23	Triagem, Gabinete, Admin	Só com consentimento
E-mail	Contato sobre a ideia	Art. 7º, III	Triagem e Admin	Nunca público
Telefone (opcional)	Contato alternativo	Consentimento	Triagem e Admin	Nunca público
Bairro / RPA	Análise territorial da participação	Art. 7º, III	Todos os perfis internos	Público (agregado)
Conteúdo da ideia	Objeto do programa	Arts. 7º, III e 23	Todos	Público após triagem
Hash de IP	Deteção de abuso	Art. 7º, IX (legítimo interesse)	Admin	Nunca público

9.3 Aviso de privacidade e coleta de consentimento

- Aviso em linguagem simples, acessível **no próprio passo de identificação**, informando: quais dados, para quê, por quanto tempo, quem acessa, e como exercer direitos.
- Os dois consentimentos são **caixas separadas e não pré-marcadas**. Agrupá-los invalidaria o consentimento por falta de especificidade.

- Data, hora e versão do texto do aviso são registradas junto ao consentimento — sem isso, não há como comprovar o que exatamente foi consentido.

9.4 Retenção e eliminação

Categoria	Prazo sugerido	Tratamento ao fim do prazo
Identificação do autor (CPF, e-mail, telefone)	5 anos após o encerramento da ideia	Anonimização: apagam-se as três colunas do documento e os contatos; o registro da ideia e sua tramitação permanecem
Conteúdo da ideia e tramitação	Permanente	Preservado como acervo de participação popular e memória legislativa
Hash de IP	6 meses	Eliminação
Registros de acesso da aplicação	12 meses	Eliminação

REQUER VALIDAÇÃO INSTITUCIONAL

Os prazos acima são **sugestões técnicas**. Devem ser homologados pela Procuradoria e pelo Encarregado de Dados (DPO) da Câmara, observadas a tabela de temporalidade documental e as normas de arquivo aplicáveis ao Poder Legislativo municipal. O sistema implementa os prazos como **parâmetros configuráveis**, justamente para absorver essa definição sem alteração de código.

9.5 Direitos do titular (art. 18)

Direito	Como o sistema atende
Confirmação e acesso	Tela "Acompanhar minha ideia" com protocolo + CPF; exportação dos dados do titular pelo Admin
Correção	Solicitação pelo canal do Encarregado; correção pelo Admin, com registro na trilha de auditoria
Anonimização / eliminação	Rotina do Admin que apaga as colunas do documento e os contatos, preservando a ideia como registro público desidentificado
Revogação de consentimento	Retirada da autorização de divulgação do nome: o nome deixa de aparecer na consulta pública imediatamente
Informação sobre compartilhamento	Não há compartilhamento com terceiros. Não há rastreadores, análise de audiência de terceiros nem recursos externos carregados nas páginas

9.6 Incidentes de segurança

Plano de resposta documentado com: detecção via alertas de registro, contenção, avaliação de risco aos titulares e **comunicação à ANPD e aos titulares em prazo razoável** (art. 48), quando houver risco relevante. O Encarregado de Dados da Câmara é o ponto focal. A trilha de auditoria é insumo essencial para dimensionar o alcance de um eventual incidente.

10. Acessibilidade e conformidade legal

OBRIGAÇÃO, NÃO DIFERENCIAL

A **Lei Brasileira de Inclusão (Lei nº 13.146/2015, art. 63)** torna obrigatória a acessibilidade de sítios da administração pública. O **Decreto nº 5.296/2004** e o **eMAG** (Modelo de Acessibilidade em Governo Eletrônico) fixam os parâmetros. Um sistema de participação popular inacessível exclui justamente a parcela da população que mais depende do canal — e expõe a Câmara a questionamento do Ministério Público.

10.1 Requisitos técnicos adotados

Requisito	Implementação
Meta de conformidade	WCAG 2.1 nível AA e diretrizes do eMAG
Estrutura semântica	HTML semântico com marcos de região, hierarquia correta de títulos, listas e tabelas com cabeçalhos associados
Navegação por teclado	Todo o fluxo — inclusive triagem e painel do gabinete — operável sem mouse, com foco sempre visível e ordem de tabulação lógica
Contraste	Mínimo 4,5:1 em texto e 3:1 em componentes. Nenhuma informação transmitida apenas por cor : cada situação combina cor, rótulo textual e forma do selo
Formulários	<code>label</code> associado a cada campo; erros ligados por <code>aria-describedby</code> e anunciados em região <code>aria-live</code> ; instruções antes do campo, não depois
Independência de JavaScript	Consulta pública e detalhe da ideia renderizados no servidor: legíveis mesmo com script desabilitado ou falho
Recursos padrão de governo	VLibras (tradução para Libras), atalho “Ir ao conteúdo”, controles de contraste e de tamanho de fonte, página de acessibilidade com os atalhos
Adaptação de tela	Desenho a partir do celular; legível a 320 px de largura e com zoom de 200% sem rolagem horizontal

10.2 Verificação

Auditoria automatizada com **axe-core** integrada ao pipeline (falha do build em violação séria ou crítica), **Lighthouse** com meta de pontuação igual ou superior a 95 em acessibilidade, e — indispensável, porque ferramenta automática detecta apenas parte dos problemas — **teste manual com leitor de tela** (NVDA) e navegação exclusivamente por teclado em cada uma das telas.

10.3 Lei de Acesso à Informação

O endpoint `/api/dados-abertos` publica o acervo em JSON e CSV, sem dados pessoais, com licença de uso livre — atendendo à transparência ativa prevista na **Lei nº 12.527/2011** e permitindo reuso por imprensa, universidades e organizações da sociedade civil sem necessidade de pedido formal.

11. Infraestrutura, implantação e operação

11.1 Dimensionamento

O volume esperado é **baixo**: estimativa da ordem de dezenas a poucas centenas de cadastros por mês, com picos durante campanhas de divulgação, e acessos de leitura concentrados na consulta pública. Trata-se de carga modesta para hardware atual.

Recurso	Recomendado	Observação
Aplicação	2 vCPU · 4 GB RAM	Container Node.js 22 LTS
Banco de dados	2 vCPU · 4 GB RAM · 50 GB SSD	PostgreSQL 16; 50 GB comportam anos de operação com folga
Proxy reverso	Compartilhado	Pode reaproveitar o Nginx já existente na Câmara
Consolidação	1 VM de 4 vCPU · 8 GB	Viável hospedar tudo em uma máquina; separar apenas se houver política interna que exija
Certificado TLS	Let's Encrypt ou certificado institucional	Renovação automática

11.2 Ambientes

Ambiente	Finalidade	Dados
Desenvolvimento	Máquina do desenvolvedor	Fictícios, gerados por rotina de carga inicial
Homologação	Validação pela Secretaria e pelos gabinetes	Fictícios. Nunca cópia de produção
Produção	Operação real	Reais, com todos os controles das seções 8 e 9

11.3 Integração e entrega contínua

```
# Pipeline executado a cada proposta de alteração
1. Lint + verificação de tipos (TypeScript em modo estrito)
2. Testes unitários      # validação de documento, máquina de estados, cifra
3. Testes ponta a ponta # cadastro → triagem → gabinete → consulta
4. Auditoria axe-core    # falha em violação séria ou crítica
5. npm audit             # falha em vulnerabilidade alta ou crítica
6. Varredura de segredos
7. Build da imagem Docker (imutável, versionada)
# Publicação em produção: aprovação manual + janela acordada com a TI
```

11.4 Cópia de segurança e recuperação

Item	Definição
Frequência	Cópia completa diária (madrugada) + arquivamento contínuo de WAL
Retenção	30 dias em ciclo diário; 12 meses em ciclo mensal
Armazenamento	Cifrado, em local distinto do servidor de aplicação
RPO (perda máxima aceitável)	15 minutos, com arquivamento de WAL
RTO (tempo máximo de retorno)	4 horas
Teste de restauração	Trimestral e documentado. Cópia não testada não é cópia — é suposição

11.5 Observabilidade

- **Registros estruturados** em JSON, com identificador de correlação por requisição. Proibido registrar CPF, senha ou token — verificado por revisão de código.
- **Verificação de saúde** em `/api/health`, consultada pelo monitoramento da Câmara.
- **Alertas** para: indisponibilidade, taxa de erro 5xx acima do normal, pico de falhas de autenticação, falha de rotina de cópia de segurança.
- **Indicadores operacionais:** tempo de resposta, fila de triagem vencida, volume diário de cadastros.

11.6 Atualização e manutenção

Node.js em versão LTS, com atualização planejada a cada ciclo; correções de segurança aplicadas em até 30 dias para severidade alta e em até 7 dias para crítica; PostgreSQL atualizado conforme a política da Câmara. **Este é o custo recorrente real da adoção de Node.js** — e precisa estar previsto, não descoberto depois.

12. Integração com o portal institucional

12.1 Comparação das opções

Opção	Avaliação	Análise
Subdomínio <code>bancodeideias.recife.pe.leg.br</code>	Recomendado	Isolamento operacional completo: implantação, atualização e eventual indisponibilidade não afetam o portal. Cabeçalhos de segurança próprios. Cookie de sessão restrito ao subdomínio. Endereço limpo e compartilhável. Custo: uma entrada de DNS e um certificado.
Rota via proxy reverso <code>/participacao-popular/banco-de-ideias</code>	Viável	Preserva o domínio único, o que pode ser preferível institucionalmente. Exige regra no Nginx e atenção ao escopo de cookies, já que o domínio passa a ser compartilhado com o Plone. Escolha legítima se houver política de domínio único.
Iframe dentro do Plone	Desaconselhado	Ver quadro abaixo.

POR QUE NÃO USAR IFRAME

- **Acessibilidade.** A navegação por teclado e por leitor de tela através da fronteira do iframe é notoriamente problemática — e acessibilidade aqui é exigência legal (seção 10), não preferência.
- **Endereço não compartilhável.** A URL da barra não muda ao navegar dentro do iframe. O cidadão não consegue enviar o link de uma ideia por WhatsApp — o que elimina o principal vetor de divulgação orgânica do programa.
- **Indexação.** Buscadores associam mal o conteúdo de iframes à página que os contém; o acervo perde alcance.
- **Segurança.** Obriga a afrouxar `X-Frame-Options` e `frame-ancestors`, reduzindo a proteção contra *clickjacking*.
- **Experiência.** Rolagem aninhada e altura fixa quebram no celular.

12.2 Continuidade visual e institucional

Estar em subdomínio não pode dar ao cidadão a sensação de ter saído da Câmara. Medidas:

- Cabeçalho com faixa institucional e identidade visual alinhada à do portal, incluindo link permanente “voltar ao site da Câmara”.
- Rodapé com endereço, telefone, Fale Conosco e Ouvidoria, iguais aos do portal.
- A página atual do Plone é convertida em **página de apresentação** do programa — o que é, para que serve, base normativa, como funciona a triagem — com botão de acesso ao sistema. Ganha-se explicação de processo, hoje inexistente.
- Tokens de cor derivados da identidade institucional, a serem confirmados contra o manual de identidade visual ou os arquivos de estilo oficiais na fase de implementação.

13. Plano de implantação

13.1 Fases

Fase	Entregável	Esforço estimado	Dependências
0	Protótipo navegável para validação com a Secretaria e a Mesa Diretora	Concluído	—
1	Projeto base, modelo de dados, migrações, carga inicial, identidade visual	1 a 2 semanas	Definição de temas e da lista de motivos de arquivamento
2	Fluxo público: assistente de cadastro, protocolo, consulta pública, acompanhamento	2 a 3 semanas	Homologação do texto do aviso de privacidade
3	Painel interno: autenticação, perfis, triagem com prazo, painel do gabinete	2 a 3 semanas	Lista de gabinetes e servidores a cadastrar
4	Apoios, prevenção de duplicidade, indicadores, dados abertos	1 a 2 semanas	—
5	Acessibilidade, testes, reforço de segurança, homologação e implantação	2 a 3 semanas	Ambiente provisionado pela TI; parecer da Procuradoria/DPO

Estimativa total: **8 a 13 semanas** para uma pessoa desenvolvedora em dedicação integral. Valores são estimativas de projeto e devem ser recalibrados após a definição do responsável pela execução.

13.2 Dependências da Câmara

- Provisionamento da VM e do PostgreSQL
- Entrada de DNS e certificado TLS
- Regra no proxy reverso
- Homologação de prazos de retenção (Procuradoria/DPO)
- Validação do aviso de privacidade
- Lista oficial de temas e de gabinetes
- Manual de identidade visual
- Definição do responsável pela operação da Triagem
- Confirmação sobre protocolo institucional já existente
- Janela de implantação e plano de comunicação

13.3 Critérios de aceite para entrada em produção

#	Verificação	Resultado esperado
1	Fluxo ponta a ponta	Cadastrar → triar → gabinete assumir → aparecer na consulta pública, com o mesmo protocolo em todas as etapas
2	Autorização	POST /api/ideias/{id}/tramitar sem sessão retorna 401 ; com perfil incorreto retorna 403
3	Máquina de estados	Transição fora do grafo (ex.: RECEBIDA → ADOTADA) retorna 422
4	Justificativa	Arquivar sem justificativa retorna 422 ; com justificativa, o autor a lê em "Acompanhar"
5	Vazamento de dado pessoal	HTML da consulta pública, /api/ideias e /api/dados-abertos não contém CPF, e-mail, telefone nem IP
6	Consentimento	Autor sem autorização de divulgação aparece como "Cidadão(ã) do Recife"
7	Auditoria	Toda transição e toda revelação de CPF geram registro consultável pelo Admin
8	Acessibilidade	Lighthouse ≥ 95; axe-core sem violação séria; fluxo completo por teclado e com NVDA
9	Validação de documento	CPF com dígito verificador inválido é rejeitado com mensagem no campo
10	Recuperação	Restauração da cópia de segurança em ambiente limpo, executada e documentada

14. Riscos e mitigações

Risco	Prob.	Impacto	Mitigação
Vazamento de CPF por falha ou acesso indevido	Baixa	Crítico	Cifra AES-256-GCM, chave fora do código, máscara por padrão, revelação registrada, minimização nas respostas, teste automatizado de vazamento (aceite nº 5)
Ausência de equipe para operar a Triagem , gerando fila parada	Alta	Alto	Indicador de prazo visível, painel de vencidos, alerta operacional. É risco de processo, não de tecnologia : exige designação formal de responsável antes da entrada em produção
Baixa adesão dos gabinetes ao painel	Média	Alto	Treinamento, ordenação por apoios (mostra relevância política), exportação da carteira, indicador público de adoção por gabinete
Node.js fora do domínio técnico da equipe	Média	Médio	Docker padroniza a operação; documentação de implantação; alternativa em Django formalmente disponível (seção 4.2)
Envio automatizado em massa ou uso político indevido	Média	Médio	Limites por IP e por documento, validação de dígito verificador, campo-armadilha, apoio único por documento, monitoramento de picos
Conteúdo ofensivo, ilegal ou difamatório publicado	Média	Alto	Publicação somente após triagem humana — nada vai ao ar automaticamente. Motivo de arquivamento específico e possibilidade de despublicação pelo Admin
Prazos de retenção não homologados a tempo	Média	Médio	Prazos implementados como parâmetro configurável; a definição jurídica não bloqueia a entrada em produção
Divergência com protocolo institucional já existente	Média	Médio	Confirmar com a Secretaria na Fase 1; se houver, o sistema passa a referenciar o número oficial em vez de criar numeração paralela
Expectativa não atendida : cidadão espera que a ideia vire lei	Alta	Médio	Comunicação explícita, em cada etapa, de que a adoção é decisão discricionária do parlamentar; linha do tempo honesta; motivo de arquivamento sempre informado

15. Roadmap posterior (v2)

Itens deliberadamente **fora** do escopo inicial, para reduzir o tempo até a primeira entrega em produção. Nenhum deles exige reescrita — todos foram considerados na modelagem.

Item	Descrição e razão do adiamento
Vínculo com a proposição	Ao adotar, registrar o número do Projeto de Lei gerado, e o público passa a ver “originou o Projeto de Lei nº X/2026”. É o item de maior impacto simbólico — fecha o ciclo e prova que participar produz resultado. Adiado por depender de integração com o sistema de proposições da Câmara. Sugere-se priorizá-lo na v2
Notificações por e-mail	Aviso automático ao autor a cada mudança de situação. Depende de servidor de e-mail institucional, política antispam e reputação de domínio
Autenticação gov.br	CPF verificado na origem, eliminando fraude de identificação e erro de digitação. Depende de processo de credenciamento junto ao gov.br, de prazo não controlável
Integração com SSO/LDAP	Elimina senha duplicada para servidores e gabinetes. A camada de autenticação já foi desenhada para receber provedor externo sem reescrita
Anexos	Fotos e documentos junto à ideia. Exige varredura antivírus, limites de tamanho, política de retenção própria e moderação de imagem
Painel geográfico	Mapa de calor das ideias por RPA e bairro. Os dados já são coletados na v1

16. Glossário

16.1 Termos legislativos, para leitores de tecnologia

Termo	Significado
Proposição	Matéria submetida à apreciação da Câmara — projeto de lei, indicação, requerimento
Gabinete	Estrutura de apoio de cada vereador; no sistema, é quem analisa e adota ideias
Triagem	Análise prévia pela Secretaria, que verifica conteúdo e identificação antes da publicação
Adoção	Ato pelo qual um gabinete assume a ideia para convertê-la em proposição
Tramitação	Percurso formal do registro entre as situações previstas
RPA	Região Político-Administrativa — o Recife possui 6, usadas para análise territorial
Resolução	Norma interna da Câmara; a de nº 2.690/2018 instituiu este Banco de Ideias

16.2 Termos de tecnologia, para leitores do Legislativo

Termo	Significado
API	Interface pela qual sistemas trocam dados diretamente, sem tela
Hash	Resumo irreversível de um dado. Serve para comparar sem armazenar o original
Cifra (criptografia)	Transformação reversível do dado, legível apenas com a chave correta
Máquina de estados	Conjunto fechado de situações e de transições permitidas entre elas
Trilha de auditoria	Registro permanente de quem fez o quê, quando e por quê
RPO / RTO	Perda máxima de dados aceitável / tempo máximo para restabelecer o serviço
WCAG / eMAG	Padrões internacional e do governo brasileiro para acessibilidade digital
LGPD	Lei Geral de Proteção de Dados (Lei nº 13.709/2018)
SSR	Renderização no servidor: a página chega pronta, sem depender de script no navegador

ENCERRAMENTO

Este documento descreve **uma proposta submetida a avaliação**. As decisões de arquitetura registradas nas seções 4 a 7 e os controles das seções 8 a 11 estão abertos a revisão pela área de Tecnologia da Informação da Câmara, que detém o conhecimento do parque tecnológico, das políticas internas de segurança e das restrições operacionais que este documento só pode presumir.

Acompanha esta especificação um **protótipo navegável** em arquivo único, que demonstra o fluxo completo das quatro etapas com persistência real entre as telas. Ele serve para validar o processo com a Secretaria e os gabinetes antes de qualquer decisão de implementação.